

Access Control Policy (Solo Developer)

Purpose

Define how access to production systems and data is granted, reviewed, and revoked for the Personal Finances application.

Scope

- Production infrastructure (hosting provider, database, monitoring/logging if used)
- Plaid dashboard
- Source control

Principles

- Least privilege: only required permissions are granted.
- Unique accounts: no shared credentials.
- Strong authentication: MFA is required on critical accounts.

Access provisioning

- Only the developer/administrator account is granted production access.
- Access is granted through provider-native IAM / role permissions (hosting + database).

Authentication requirements

- MFA enabled for:
 - Email account used for account recovery
 - Source control provider
 - Hosting/cloud provider
 - Plaid dashboard
- Password manager used to generate and store strong unique passwords.

Application MFA (end-user login)

- The application supports MFA using WebAuthn/passkeys (security key or platform biometrics/PIN).
- When MFA is enforced (production setting), users authenticate with:
 1. Password (knowledge factor)
 2. WebAuthn/passkey verification (possession + user verification via PIN/biometrics)
- MFA enforcement is controlled via environment configuration (e.g., enabled in production and may be disabled in local development).

Access review

- Quarterly self-review of:
 - Active API/admin keys
 - Database access credentials
 - Plaid dashboard users (should remain single user)

Revocation

- If access is no longer needed or compromise is suspected:
 - Rotate/disable affected tokens/keys immediately
 - Rotate database passwords/connection strings
 - Rotate JWT secret
 - Regenerate Plaid secrets as applicable

Environment separation

- Non-production environments (local/dev) use separate configuration from production.
- Production secrets are not reused in local development.